TOURSHIELD

API de Turismo e Reservas

Estatística e segurança OWASP

Projeto de Bloco | Trabalho Prático 2

Helena Gomes
25 de outubro de 2026

Competência integradora: implementar análise estatística completa e controles OWASP Top 10 na API FastAPI auditada por ZAP.

Análise	API	Auditoria passiva
3.000 mensagens	SQLModel + ownership	ZAP 2.17.0
Mann-Whitney + efeito + IC	42 testes aprovados	0 High / Medium / Low

Foco do domínio: fraude de benefícios e geolocalização. O TP2 protege o atendimento e a posse de recursos; não implementa modelo de fraude, classificação ou agente.

github.com/lenagomesz/tourshield-api-pb-tp1

O mesmo repositório do TP1 foi atualizado. Este PDF acompanha o notebook, o código, os dados, os testes e o relatório exportado pelo ZAP.

01 / Problema e dados

O objetivo analítico é caracterizar mensagens de turismo e reservas para preparar a classificação de intenções. A hipótese H2 do TP1 propôs que mensagens de reservas exigem mais contexto que consultas de localização. O objetivo de segurança é impedir que uma sessão acesse reservas de outro usuário ou atribua a si benefícios.

Propriedade	Descrição
Dataset	CLINC150, recorte curado de 20 intenções; Larson et al. (2019), Clinc.
Fonte / licença	github.com/clinc/oos-eval; CC BY 3.0 Unported. Cópia integral e atribuição em data/.
Shape e tipos	Original (3.000, 4): sample_id, message, intent, split, como strings. Limpo (3.000, 6), com n_chars e n_words.
Qualidade	Zero ausentes, duplicatas normalizadas e conflitos de rótulo. Nenhuma linha removida, imputada ou traduzida.
Distribuição / splits	150 mensagens por classe (5%). Treino 2.000, validação 400, teste 600; sem sobreposição de chave textual normalizada.
Rastreabilidade	Commit e SHA-256 em data/provenance.json. Bruto e CSVs presentes para execução offline.

As regras do TP1 são mantidas: strip de bordas, chave auxiliar para auditar duplicatas, preservação de texto e splits; nenhum corte automático por outlier de comprimento. Há 98 mensagens acima do limite IQR de 18 palavras, mantidas como potencialmente legítimas.

Os enunciados são de crowdsourcing em inglês e intenção única, não chamados reais de uma agência. Categorias de recompensas são genéricas; a base não tem coordenadas GPS, transações ou fraude confirmada. O recorte é escolha do projeto, não domínio oficial único do CLINC150.

02 / Análise de correlação

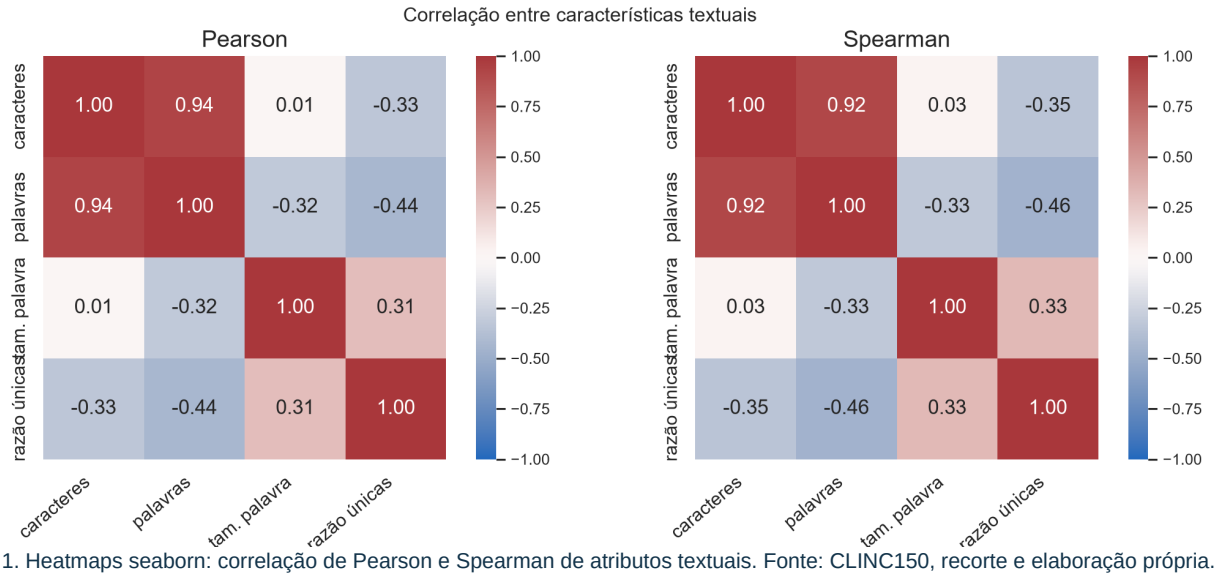


Figura 1. Heatmaps seaborn: correlação de Pearson e Spearman de atributos textuais. Fonte: CLINC150, recorte e elaboração própria.

Variável	Definição
n_chars	Caracteres da mensagem
n_words	Tokens delimitados por espaços
mean_word_length	Média de caracteres das palavras
unique_ratio	Palavras distintas / total de palavras, em casefold

Caracteres e palavras apresentam Pearson **r=0.9351** e Spearman **rho=0.9214**. A associação forte é esperada porque ambas medem o mesmo texto. Sugere redundância entre atributos, sem provar causalidade nem utilidade preditiva.

Não foi atribuído código numérico arbitrário às intenções para correlacioná-las. As demais variáveis também são derivadas do comprimento e vocabulário do texto; relações matemáticas entre elas exigem cautela na interpretação.

No futuro modelo, o valor incremental desses atributos deve ser avaliado em treino/validação. A correlação global exploratória não autoriza usar o teste para selecionar hiperparâmetros.

03 / Scatter plots e padrões

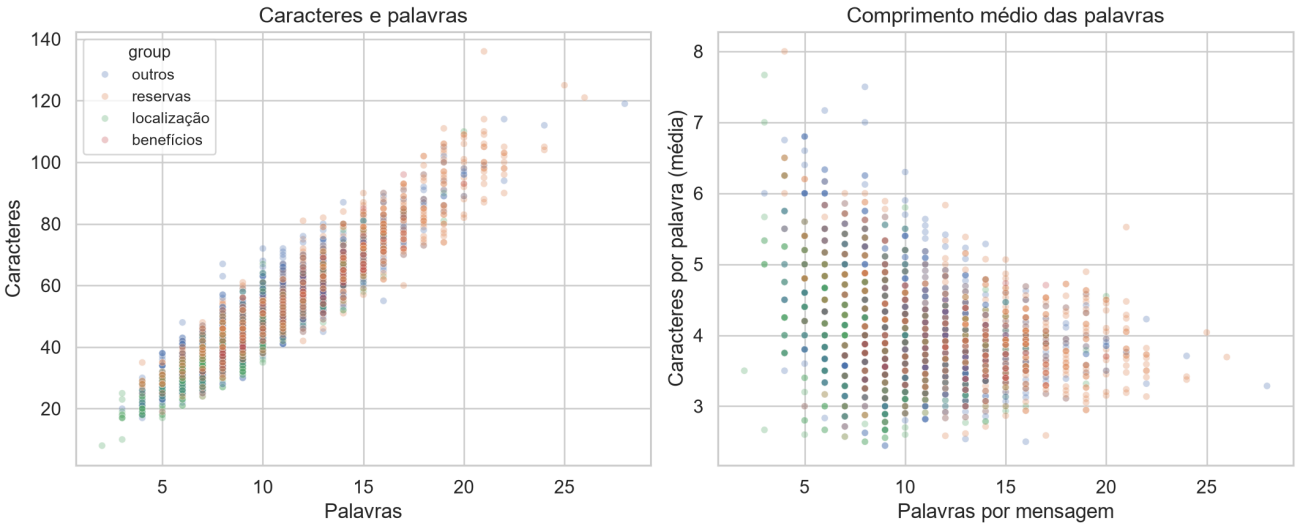


Figura 2. Dispersão de caracteres/palavras e de comprimento médio das palavras. Os quatro grupos são curados para a análise; pontos translúcidos reduzem o efeito da sobreposição.

O primeiro scatter confirma o crescimento conjunto de palavras e caracteres. Mensagens de reservas aparecem com frequência nos comprimentos maiores, mas os grupos se sobrepõem. No segundo, número de palavras e tamanho médio da palavra não formam fronteiras claras de intenção.

Estatística	Caracteres	Palavras
Média / DP amostral	50,09 / 17,37	10,26 / 3,65
Mediana	48	10
Q1 / Q3	38 / 60	8 / 12
Mínimo / máximo	8 / 136	2 / 28

Insight: não definir um limiar de comprimento como se ele identificasse intenção. Reservas e localização incluem mensagens curtas e longas; vocabulário e semântica precisam ser considerados no futuro classificador.

O balanceamento de 150 exemplos por intenção vem da construção do benchmark. Não traduz a prevalência de dúvidas reais e não permite estimar demanda ou fraude operacional.

04 / Teste formal da H2 do TP1

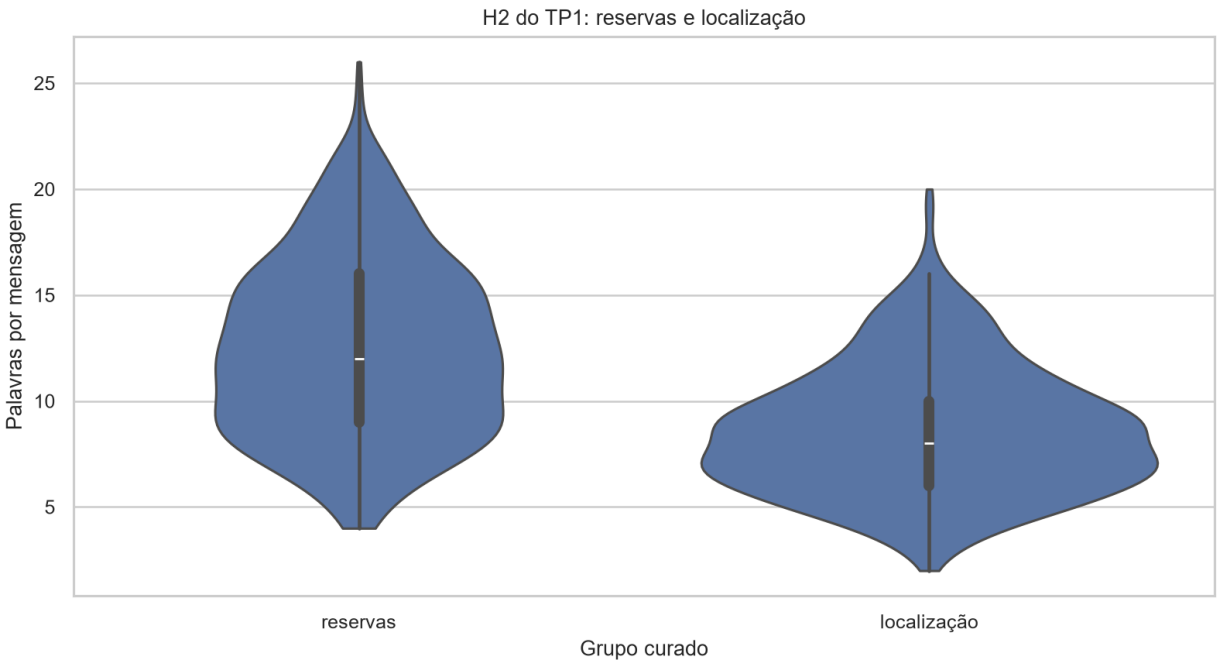


Figura 3. Comparação de comprimento. Reservas: 750 mensagens; localização: 600. Fonte: elaboração própria.

H0: distribuições iguais de n_words nos grupos. **H1:** distribuições diferentes. Teste bilateral Mann-Whitney U (SciPy), alfa=0,05, método assintótico com correção de empates e continuidade; um contraste principal.

Medida	Resultado
Medianas	Reservas: 12; localização: 8 palavras
U / p-valor	346424 / 1.2825e-65
Cliff's delta	0.5397 (positivo: reservas maiores)
Diferença de medianas / IC95%	4 palavras / [3; 5], bootstrap percentil, 5.000 reamostragens, semente 42

Interpretação: rejeita-se H0 neste benchmark. A direção observada favorece reservas mais longas; a probabilidade empírica de superioridade, contando empates pela metade, é 76,98%. O p-valor não é a chance de H0 ser verdadeira e não mede relevância prática.

O teste compara distribuições; não é automaticamente teste de medianas com formatos distintos. O IC estima a diferença de medianas separadamente. A hipótese veio desta mesma base no TP1: resultado exploratório, sem confirmação externa.

05 / Insights, limites e próximos passos

Insights principais

1. Caracteres e palavras têm informação redundante; testar ganho incremental desses atributos no futuro modelo.
2. Reservas tendem a ser mais longas nesta comparação, mas com sobreposição; não transformar a diferença em regra rígida de intenção.
3. Intenções balanceadas exigem cautela ao generalizar para atendimento real.
4. Saldo e resgate de recompensas continuam decisões semânticas diferentes, separadas da autorização de benefício.

Limitações estatísticas

Os grupos misturam várias intenções; essa composição pode explicar parte do efeito. O teste pressupõe observações independentes, mas não há IDs de participantes para verificar enunciados do mesmo autor. A reamostragem individual não corrige dependência, viés de coleta ou validade externa.

A hipótese foi sugerida pelos mesmos dados no TP1. O valor muito pequeno de p não corrige esse reuso exploratório. O idioma inglês, intenção única, crowdsourcing e exclusão de out-of-scope limitam a aplicação a clientes reais em português.

Limitações do domínio

Não existem fraude confirmada, GPS, transações ou saldo associado a usuário. A EDA não identifica fraude de benefícios ou spoofing de localização. JWT comprova sessão, sem provar local físico ou elegibilidade para desconto.

Próximos passos para classificação

Comparar TF-IDF com classificador linear a baselines majoritário e de comprimento. Ajustar apenas em treino/validação; usar teste uma vez no resultado final. Reportar macro-F1, recall por intenção e matriz de confusão. Obter base externa autorizada em português, com multi-intenção e out-of-scope.

Nenhuma saída futura de classificação deverá aprovar resgate ou substituir ownership, saldo e regras de elegibilidade no servidor. Dados próprios e rótulos específicos serão necessários para estudar fraude.

06 / API, SQLModel e ownership

Rota	Contrato e proteção
GET /health	Público; 200, sonda de vida
POST /auth/token	Form AuthInput extra=forbid; Argon2; JWT ou 401; limite 429
POST /predict	PredictRequest extra=forbid; Bearer; placeholder, sem modelo
POST /reservations	ReservationInput extra=forbid; destino; owner obtido do sub; 201
GET /reservations/{id}	JWT obrigatório; consulta ID + owner; 404 para outro usuário ou inexistente

SQLModel substitui o SQLite raw do TP1. Usuários e reservas são tabelas SQLModel; consultas usam select, where, Session.get/add/commit. Não existe SQL textual no código da API, CLI ou testes. O mecanismo gera parâmetros vinculados e oculta valores de parâmetros em erros.

A reserva é um recurso local de demonstração, sem compra externa. Seu status inicial é requested. O cliente só informa destination: owner e status extras são rejeitados. O UUID dificulta enumeração, mas a proteção real é a condição owner == usuário autenticado na consulta.

```
select(Reservation).where(
    Reservation.id == str(reservation_id),
    Reservation.owner == username
)
```

Dois usuários foram exercitados no pytest e no tráfego do ZAP: proprietário recebe 200; outro usuário recebe 404, sem revelar destino ou confirmar existência. Sem token recebe 401.

JWT HS256 de 15 minutos mantém validação de exp, iat, sub, iss e aud e consulta de conta ativa. Mensagem/GPS não são persistidos; destino da reserva é persistido e protegido. Não há aprovação de benefício por coordenada declarada.

07 / Headers, CORS e rate limiting

Controle	Configuração
HSTS	max-age=31536000; includeSubDomains
X-Frame-Options / X-Content-Type-Options	DENY / nosniff
CSP	default-src 'none'; frame-ancestors 'none'; base-uri 'none'; form-action 'none'
Cache / privacidade	no-store; Pragma no-cache; Referrer-Policy no-referrer; Permissions-Policy restritiva
CORS	Allowlist http://localhost:3000; GET/POST; Authorization/Content-Type; sem credenciais por cookie
Superfície	Debug falso; docs/redoc desativados; host allowlist; limite de body 16 KiB e leitura 10 s

O middleware aplica headers em sucessos e erros, inclusive 401/404/422/429. CORS não é autorização e não protege contra clientes fora do navegador. HSTS só atua em HTTPS; o scan usou TLS local. A CSP fechada dispensa scripts de Swagger, que permanece desativado; o contrato JSON segue disponível.

Rate limiting de autenticação

Janela deslizante: **5 requisições por IP em 60 segundos**, contabilizando sucessos e falhas antes de parsing e Argon2. A sexta recebe 429 e Retry-After. O limite permite erros de digitação e reduz brute force e custo de hashing na demonstração.

Lock e relógio monotônico evitam corrida/variação do relógio; estado tem teto de 10.000 IPs e falha fechada quando cheio. X-Forwarded-For não é adotado na execução orientada com --no-proxy-headers. Teste confirma bloqueio e recuperação da janela.

Limite: um processo/worker, memória limpa no reinício. NAT pode agrupar usuários e ataques distribuídos podem contornar limite por IP. Produção exige armazenamento compartilhado e política de proxy/conta adequada.

08 / Cobertura OWASP Top 10

IDs 2021 usados na disciplina; matriz completa e correspondência para a edição 2025 em docs/owasp_tp2.md. Controles não equivalem a certificação.

Risco 2021	Controle / evidência
A01 - Acesso	JWT, ownership por ID+owner, 404 uniforme, teste BOLA
A02 - Criptografia	Argon2id, segredo externo, JWT validado, TLS no scan, HSTS
A03 - Injeção	SQLModel sem SQL raw; inputs com extra=forbid; dados nunca executados
A04 - Design	Owner/status no servidor; nenhum resgate autorizado; limites explícitos
A05 - Configuração	CSP/headers, CORS, hosts, debug falso, erros genéricos, docs desligados
A06 - Dependências	88 pacotes no snapshot pip-audit; 0 vulnerabilidades conhecidas; lock transitivo
A07 - Autenticação	JWT 15 min, conta ativa, erros genéricos e 5 logins/IP/minuto
A08 - Integridade	Dados por hash/commit, dependências fixadas e ferramentas com SHA-256
A09 - Logs	JSON com request_id, método, rota e status; sem senha/JWT/texto/GPS
A10 - SSRF	Sem HTTP externo na API, callbacks ou dereferência de URLs fornecidas

Edição 2025

A matriz atual também trata A10:2025 (condições excepcionais): ausência de segredo impede startup; erro inesperado vira 500 genérico com headers e log; body/timeout geram 413/408. SQLModel oculta parâmetros. Esses comportamentos têm testes específicos.

Pendências de implantação

TLS com certificado válido, limiter distribuído, MFA quando aplicável, revogação individual, backup, coletor/retentor de logs e alertas externos não estão prontos para produção. A API não tem integrações externas de reserva ou benefícios. Para o escopo atual, SSRF não possui fluxo executável.

09 / Auditoria passiva OWASP ZAP

ZAP **2.17.0** e Java Temurin 21 portáteis; downloads oficiais com SHA-256 verificados. Modo **safe**, sem active scan ou spider. 61 regras passivas habilitadas. Alvo desta execução: https://localhost:62418.

A API rodou com TLS e certificado descartável. O cliente confiou no proxy ZAP somente no processo de teste; trust store do sistema não foi alterada. O runner não escaneia serviços externos e usa contas, banco e segredos efêmeros.

Foram exercitadas **20 requisições**, cobrindo login, health, OpenAPI, predição, reserva própria/de outro usuário, erros, CORS e rate limit. A fila recordsToScan foi conferida em **0** antes da exportação. Ledger e regras em scan-metadata.json.

Severidade	Ocorrências
High	0
Medium	0
Low	0
Informational	8

Finding	Análise / status
10015 - Cache-control 4 ocorrências informativas	Aceito: evidência no-store é proteção intencional. Evita cache de respostas potencialmente sensíveis.
10111 - Auth request 3 ocorrências informativas	Aceito: identifica campo password no login esperado; não é prova de exposição. TLS, hash, throttling e no-store aplicados.
10112 - Session response 1 ocorrência informativa	Aceito: identifica access_token, saída contratual. JWT expira em 15 min e não é enviado em URL.

Nenhum Medium/High foi detectado; não há finding dessas severidades para corrigir ou aceitar nesta execução. O scan foi realizado após aplicar os controles; não foi inventado um relatório anterior para simular correção.

HTML e JSON foram exportados pela própria API do ZAP. Apenas segredos efêmeros eventualmente presentes foram redigidos; os findings e severidades permanecem. Oito ocorrências informativas correspondem a três tipos de alerta.

10 / Validação, execução e entrega

Verificação	Evidência
pytest tests/	42 testes aprovados; reports/tests_tp2.xml
Casos obrigatórios	Sem token 401; reserva alheia 404; campo extra 422
Cobertura adicional	JWT, CORS, headers, limiter, expiração de janela, body, log sem segredos e erro genérico
Notebook	10 células executadas; heatmap, dois scatters, teste com p-valor e efeito
Dependências	pip-audit: 0 vulnerabilidades conhecidas no snapshot; não é garantia futura
Scan	ZAP real em TLS, 20 requisições, fila zerada, sem exclusões de findings

```
python -m venv .venv
.\.venv\Scripts\Activate.ps1
python -m pip install -r requirements-lock.txt
# Configure JWT_SECRET no .env (instrução no README).
python -m scripts.create_user helena
uvicorn main:app --reload --no-proxy-headers --no-server-header
# Outro terminal:
python eda/eda_tp2.py
pytest tests/
python -m scripts.setup_zap
python -m scripts.run_zap
```

Limites da auditoria

ZAP passivo só analisa mensagens exercitadas; não explora SQLi ou prova ausência de BOLA. Os testes complementam o scan sem substituir pentest completo. O certificado autoassinado serve ao laboratório. Um aviso de depreciação TestClient/httpx não causou falhas.

Entrega e referências

Repositório: github.com/lenagomesz/tourshield-api-pb-tp1.
ZAP: reports/zap/zap-report.html ou zap-report.json; findings.md.
EDA estruturada: reports/tp2/eda_report.md; notebook: eda/eda_tp2.ipynb.

Larson et al. (2019): aclanthology.org/D19-1131 (CC BY 3.0).
ZAP: zaproxy.org/docs/api.
OWASP: Top 10:2021 e Top 10:2025.
SQLModel: documentação oficial.